Laporan Progres Penelitian Tesis

Integrasi CTI OpenCTI ke SEPSES Knowledge Graph dengan Provenance dan Validitas Waktu untuk Penilaian Kerentanan

Made Agastya — Magister Artificial Intelligence, Universitas Gadjah Mada

17 Oktober 2026 · Pembimbing: Kabul Kurniawan, Ph.D.

Ringkasan

Laporan ini menggantikan bimbingan 2 yang semula dijadwalkan 16 Oktober 2026. Isinya: progres sejak pertemuan 1 (18 Juni 2026), perjalanan dan alasan perubahan topik, rencana ke depan, dan keputusan yang saya mohonkan dari Bapak.

Perubahan arah. Pada pertemuan 1 saya mengusulkan atribusi kelompok APT dengan *heterogeneous graph neural network*. Sesudah mengikuti arahan Bapak (mulai dari *use case* dan CQ, memakai ontologi SEPSES, menautkan *vulnerability* ke CVE/CPE, pendekatan *knowledge-driven*) dan memeriksa data, fokus penelitian saya ubah menjadi **integrasi CTI OpenCTI ke SEPSES Knowledge Graph yang benar, dapat ditelusuri sumbernya, dan sesuai waktu keputusan**, untuk penilaian kerentanan aset berbasis konteks ancaman. Data yang dipakai tetap sama: 986 laporan OpenCTI (konektor AlienVault).

Masalah yang dibuktikan dari data. Bila CTI digabung ke SEPSES tanpa memperhatikan waktu, 45,8% asosiasi CVE–ancaman pada 30 September 2025 berasal dari laporan yang baru terbit sesudahnya, dan 51,4% sudah usang pada 31 Desember 2025 (jendela 90 hari). Seluruh 456.585 relasi STIX di ekspor OpenCTI bertanggal impor (Maret 2026), sehingga waktu bukti harus diambil dari tanggal terbit laporan.

Progres utama.

- Draft proposal v3 (Bab I–IV dan lampiran) sudah lengkap.
- Alur kerja dari Bapak sudah dijalankan satu putaran pada sampel kecil: CQ → T-box → pemetaan → KG di *triplestore* Fuseki → kueri SPARQL. Dari tujuh CQ yang dicoba, lima terjawab dan dua terjawab sebagian.
- Kode dan dokumentasinya ada di GitHub.

Yang saya mohonkan. Persetujuan atas pergantian topik dan rumusan masalah, serta beberapa keputusan teknis (lihat bagian *Pertanyaan untuk Bapak*). Daftar lengkapnya ada di Lampiran A proposal.

Berkas yang dilampirkan:

Berkas	Isi
`draft-proposal-bimbingan-v3-draft-14.pdf` (dan `.docx`)	Naskah proposal
Repositori GitHub `sepses-cti-kg`: [tautan GitHub menyusul]	Kode prototipe, ontologi, kueri, hasil, dokumentasi kode, dan log progres (`PROGRES.md`)
Laporan ini	Progres, perbandingan versi penelitian, rencana, dan pertanyaan

Progres sejak pertemuan 1

Tanggal	Pekerjaan	Hasil	Lokasi di GitHub
Agustus 2026	Kerangka v1 dan studi kelayakan (prioritisasi kerentanan)	Profil data OpenCTI, CVE, SEPSES; *pilot exposure* dan *provenance*	— (arsip lokal)
7 Oktober	Perampingan v1 (v2)	Fokus seleksi bukti; disimpulkan sulit dievaluasi pada data ini	— (arsip lokal)
9 Oktober	Pemetaan ulang masalah dari data	Lima kandidat masalah dinilai; dipilih integrasi CTI–SEPSES yang sadar waktu	`data-checks/`
10 Oktober	Draft proposal v3	Bab I–IV; gambar T-box dan contoh A-box; CQ1–CQ8 dengan contoh nyata CVE-2025-8088	`proposal/`
11 Oktober	**Prototipe KG v0.1**	7 laporan, 3 CVE, 5 aset skenario; 4.739 *triple*; Fuseki; SHACL lolos	`prototipe-kg/`
11 Oktober	Kuantifikasi temuan prototipe pada seluruh korpus	Angka pendukung untuk keputusan teknis (bagian *Temuan pendukung*)	`data-checks/kuant01_*`, `kuant02_*`
11–17 Oktober	Repositori GitHub, dokumentasi kode, draft v3-draft-14 (+ DOCX)	Peta proposal ↔ kode (Lampiran D proposal); panduan kode langkah demi langkah	`docs/`, `README.md`

Hasil prototipe KG v0.1

CQ	Status	Hasil pada sampel
CQ1 *exposure* aset	Terjawab	8 pasangan aset–CVE: 4 TRUE, 1 FALSE, 3 UNKNOWN, masing-masing dengan alasan pencocokan
CQ2 CVSS/CWE	Sebagian	Ada untuk 3 CVE contoh; SEPSES belum punya kelas CVSS v4.0; CVE sebelum 2025 belum dimuat
CQ3 konteks ancaman	Terjawab	Tanpa memperhatikan waktu: 13 aktor/*malware*. Pada t = 30 September 2025: 7. Enam berasal dari laporan yang belum terbit
CQ4 relevansi sektor	Terjawab	Sektor Government untuk CVE-2025-8088 hanya didukung laporan 23 Oktober, sehingga belum sah pada 30 September
CQ5 status bukti per t	Terjawab	Setiap laporan diberi label berlaku, belum terbit, atau usang
CQ6 *provenance*	Sebagian	Dapat ditelusuri ke laporan dan tanggal; pembuat selalu AlienVault, penerbit asli hanya di URL
CQ7 status KEV per t	Terjawab	Pada 30 September 2025 hanya CVE-2025-8088 yang berstatus KEV
CQ8 tier prioritas	Belum	Iterasi berikutnya

Hasil kueri yang dijalankan di Fuseki sama persis dengan hasil rdflib. Langkah menjalankannya ada di

`README.md` repositori (`./jalankan.sh --fuseki`).

Perjalanan penelitian

Aspek	Penelitian lama (Mar–Jun 2026)	v1 (Agustus)	v2 (7 Oktober)	v3 (sekarang)
Fokus	Atribusi kelompok APT	Prioritisasi aset–CVE dengan bukti CTI yang dapat ditelusuri, sadar waktu, dan sadar dependensi sumber	Seleksi bukti sadar dependensi untuk *ranking*	Integrasi CTI–SEPSES yang benar, dapat ditelusuri, dan sadar waktu
Metode	KG dari STIX + R-GCN/HAN/HGT + GNNExplainer	Ontologi SEPSES–CTI, *exposure*, *ranking*, *EvidencePath*	*Selector* + *evidence certificate*	Kosakata SEPSES/ICS-SEC, graf bernama per laporan, aturan waktu, SPARQL per CQ
Evaluasi	F1 klasifikasi node	*Utility*, *robustness*, *fidelity*	*Robustness*	Ketepatan jawaban CQ, bukti sah waktu, kelengkapan *provenance*
Pendekatan	*Machine learning*	Campuran	KG	*Knowledge-driven*
Penyimpanan	GraphDB → Neo4j	File RDF	—	Fuseki
Status	KG dibangun; model belum dijalankan	*Pilot* selesai	Draft	Proposal + prototipe berjalan

Penelitian lama sempat membangun KG dari ekspor yang sama (54.586 entitas, 219.279 relasi), tetapi laporan belum tertaut ke isinya, CVE belum tertaut ke CVSS/CWE, dan model atribusinya belum dijalankan. Perbandingan lengkap beserta kecocokan setiap versi dengan data dan arahan Bapak tersedia sebagai dokumen terpisah bila diperlukan.

Alasan perubahan

1. Label untuk atribusi maupun *ranking* tidak cukup pada data. Tidak satu pun dari 355 aktor di data memiliki ID ATT&CK, dan nama aktor tidak seragam (Lazarus muncul dengan lima nama). Akibatnya label kelompok APT untuk klasifikasi sulit dijamin benar. Label eksploitasi untuk *ranking* (CVE masuk KEV sesudah t) juga hanya memberi 0–8 kasus positif.

2. Masalah integrasi terukur langsung pada data. Selain angka bocor dan usang di atas, 11,5% relasi "X menargetkan CVE" dimuat lebih dari satu laporan dengan selisih waktu median 33 hari. Artinya waktu dan sumber bukti harus dicatat per laporan, bukan per relasi. Masalah ini dapat dievaluasi tanpa label eksploitasi, cukup dengan *gold standard* jawaban CQ.

3. Pelajaran dari *pipeline* lama. KG lama tidak menautkan laporan ke isinya, padahal laporan adalah satu-satunya sumber waktu yang sahih. CVE juga belum tertaut ke SEPSES. v3 menjadikan kedua hal ini inti rancangan.

4. Kesesuaian dengan arahan Bapak pada pertemuan 1:

- mulai dari *use case* dan CQ konkret;
- taksonomi → kelas → relasi;
- memakai ulang ontologi SEPSES;
- menautkan *vulnerability* ke CVE/CPE;

- KG dikueri dengan SPARQL di *database*;
- mulai dari sampel kecil dan iteratif;
- *knowledge-driven*, bukan ML.

Kesesuaian per butir ada di Lampiran C proposal.

Temuan pendukung untuk keputusan teknis

Temuan (seluruh korpus)	Angka	Terkait keputusan
Relasi STIX bertanggal impor, bukan waktu kejadian	100% (456.585 relasi)	Waktu bukti dari laporan
Relasi "targets CVE" dimuat >1 laporan	11,5%	K3: pola *provenance*
Laporan dengan URL penerbit asli (di balik konektor AlienVault)	98,4%, 192 domain	K15: *provenance* dua tingkat
Entri produk terdampak berstatus bawaan *unknown*	75,4%	Logika tiga nilai pada *exposure*
CVE 2025 yang hanya punya CVSS v4.0 (belum ada di kosakata SEPSES)	15,5%	Perluasan kosakata
CVE yang disebut CTI dan tercakup data lokal (CVE List v5 + SEPSES)	77,0% (271/352)	K5: sumber data CVE 2020 dan 2024
CVE yang punya *indicator* di laporan yang sama	90,3%	K14: lingkup *indicator*
Indicator berstatus dicabut pada *snapshot* 2026	53,8%	K16: syarat `revoked` per t

Rencana ke depan

Urutan berikut dihitung dari minggu sesudah keputusan Bapak:

Minggu	Kegiatan	Keluaran
0	Mencatat keputusan Bapak; menyesuaikan proposal	Catatan keputusan; draft berikutnya
1–2	Iterasi prototipe v0.2: pemetaan *indicator* dan CQ3b, penyatuan varian nama aktor (*entity linking*), *provenance* dua tingkat, CVSS v4, memuat SEPSES untuk CVE lama, CQ8 tier	Prototipe v0.2 dan tabel status CQ baru
2–3	*Screening* literatur (354 rekaman dari Scopus, IEEE, dan korpus sebelumnya) dan finalisasi Bab II	Bab II dengan diagram PRISMA
3–4	Rancangan *gold standard* (60 CVE: 20 *dev*, 40 *test*) dan pembekuan ambang evaluasi	Protokol evaluasi
4	Revisi akhir proposal	Proposal siap sidang

Progres mingguan akan saya catat di `PROGRES.md` repositori GitHub dan saya laporkan ringkas di grup WhatsApp.

Pertanyaan untuk Bapak

Prioritas utama (menentukan arah):

1. **Pergantian topik (K0).** Apakah perubahan dari atribusi APT ke integrasi CTI–SEPSES untuk penilaian kerentanan dapat diterima?
2. **Masalah dan RQ (K1, K2).** Apakah satu masalah dengan satu RQ dan tiga ukuran (kebenaran jawaban, keabsahan waktu, kelengkapan *provenance*) sudah tepat?
3. **Lingkup *indicator* (K14).** Saya usulkan *indicator* dimodelkan (relasi *indicator–malware* sesuai arahan Bapak) dan dipakai untuk satu CQ turunan, tetapi *observable* dan kualitas IOC tidak dievaluasi. Apakah ini tepat?

Keputusan teknis (menentukan iterasi berikutnya):

4. **Pola *provenance* (K3).** RDF-star seperti ICS-SEC KG, atau graf bernama per laporan seperti di prototipe? Apakah lab memakai Fuseki atau Virtuoso?
5. **Implementasi pemetaan (K4).** Memperluas *pipeline* RML/Java SEPSES, atau Python dengan IRI dan kosakata yang sama?
6. ***Provenance* dua tingkat (K15).** Perlukah penerbit asli (misalnya ESET atau QiAnXin) dicatat selain konektor AlienVault?
7. **Syarat `revoked` per t (K16).** Status `revoked` di ekspor adalah keadaan 2026. Apakah OpenCTI dapat mengekspor riwayat versi objek, atau syarat ini dicatat sebagai batasan?
8. **Data CVE (K5).** Versi kosakata SEPSES mana yang menjadi acuan, dan dari mana sebaiknya CVE 2020 dan 2024 yang belum tercakup diambil?

Lain-lain:

9. Apakah tinjauan pustaka untuk proposal perlu berupa SLR formal (PRISMA) atau cukup pemetaan literatur?
10. Kapan jadwal bimbingan berikutnya, dan apakah ada target waktu sidang proposal?

Lampiran: isi repositori GitHub

Folder	Isi
`README.md`, `PROGRES.md`	Ringkasan proyek, cara menjalankan, log progres
`prototipe-kg/`	Prototipe KG v0.1: T-box, SHACL, *pipeline* Python, kueri SPARQL per CQ, Fuseki, hasil, visualisasi
`data-checks/`	Skrip pemeriksaan data (sumber angka di proposal dan laporan ini) beserta keluarannya
`infrastruktur/opencti/`	Konfigurasi Docker OpenCTI dan konektor AlienVault yang dipakai mengumpulkan data
`docs/`	Peta proposal ↔ kode, alur data, panduan kode, penjelasan ontologi dan kueri
`proposal/`, `laporan/`	Draft proposal dan laporan progres (PDF)